UNIVERSITY DENIS SASSOU N'GUESSO

Faculty of Applied Sciences

Theme:

Information Systems Security Policy (ISSP) for SRI Pay Online

Presented by:

- **KOKOLO Wilfride Daïna**
- **ABOMBI GANKOUI Noryl Caleb Jordy**
- **GAMI OKO Jonas M.**
- **ENGAMBET Isaac**

I. INTRODUCTION

Protecting customer data is the top priority, especially when it comes to sensitive information such as credit card details. With the explosion of cyberattacks, companies like SRI Pay Online must adopt a proactive approach. This ISSP describes security rules, measures to implement, and emergency plans in case of an incident. It aligns with standards such as Congolese law No. 29-2019 on the protection of personal data and PCI DSS (Payment Card Industry Data Security Standard)

II. MAIN OBJECTIVES OF THE ISSP

1. Protecting Sensitive Data

The goal is to block unauthorized access to critical customer information, such as card numbers or personal data through tools like encryption and multi-factor authentication. This refers to Article 63 of Law 29-2019, which mandates the confidentiality of personal data.

Example: only authorized employees can access the customer database.

2. Ensuring Service Continuity

The aim is to prevent disruptions caused by attacks through adequate preparation: regular backups, robust firewalls, and a contingency plan in case of problems.

Example: if a hacker attacks, data is quickly restored to avoid a complete shutdown.

3. Regulatory Compliance

Compliance with laws such as Congolese law No. 29-2019 and security standards is required not only to avoid fines and legal issues but above all to protect the rights and freedoms of individuals concerned. Per Article 7 of the law, customer data is only retained for the duration necessary for its processing, and with the consent of the data subjects.

4. Strengthening Trust

The more we demonstrate strong data protection, the more confident customers feel. This reinforces trust between clients and the company.

Example: a secure site (with HTTPS padlock) reassures users when paying online.

III. THE 10 RETAINED POLICIES

The following 10 policies cover all aspects of security to ensure comprehensive protection:

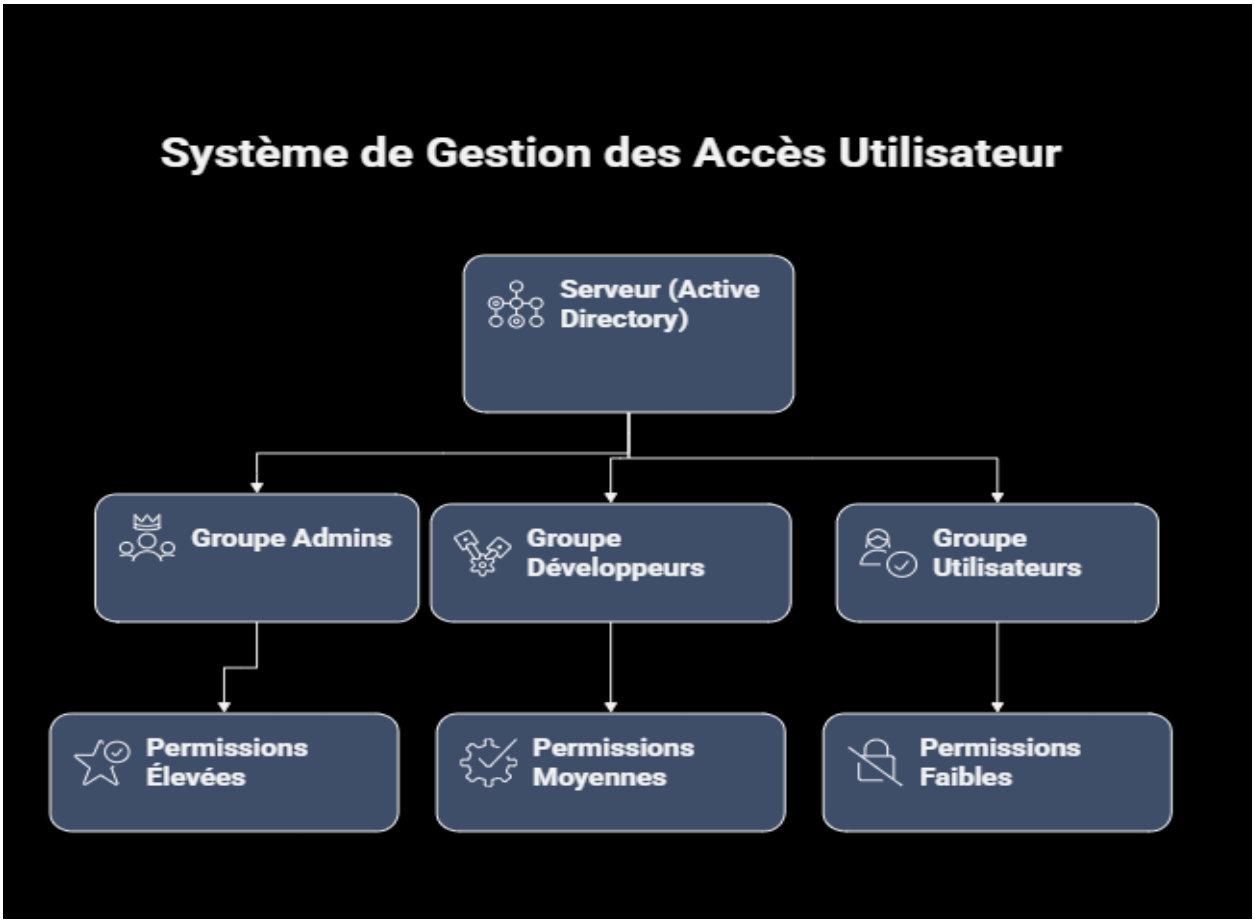
	Policy	Objective	Concrete Example
1	**Access Management**	Restrict access to critical resources.	*Database access is limited to authorized developers.*
2	**Data Security**	Protect sensitive customer information.	*Credit card numbers display only the last 4 digits.*
3	**Password Security**	Strengthen authentication.	*All employees must change passwords every 90 days.*
4	**Application Security**	Protect web applications.	*A WAF blocks SQL injection attempts on the payment portal.*
5	**Backup Management**	Prevent data loss.	*Customer database backups are replicated to AWS cloud.*
6	**Incident Management**	React to violations and incidents.	*A detected phishing incident is analyzed with SIEM alerts.*
7	**Network Security**	Block attacks on infrastructure.	*Remote employees access the network via VPN with MFA.*
8	**Updates & Patches**	Address vulnerabilities.	*A critical Windows Server flaw is patched within 24 hours.*
9	**Training & Awareness**	Reduce human errors.	*Phishing simulations identify employees who need training.*
10	**Compliance & Audit**	Adhere to standards and laws.	*An annual audit ensures PCI DSS compliance.*

IV. POLICY DETAILS

1. Access Management Policy

Using Active Directory (AD) to manage users ensures that only those with a genuine need can access critical data. This complies with PCI DSS Requirement 7, which mandates restricting data access on a need-to-know basis.

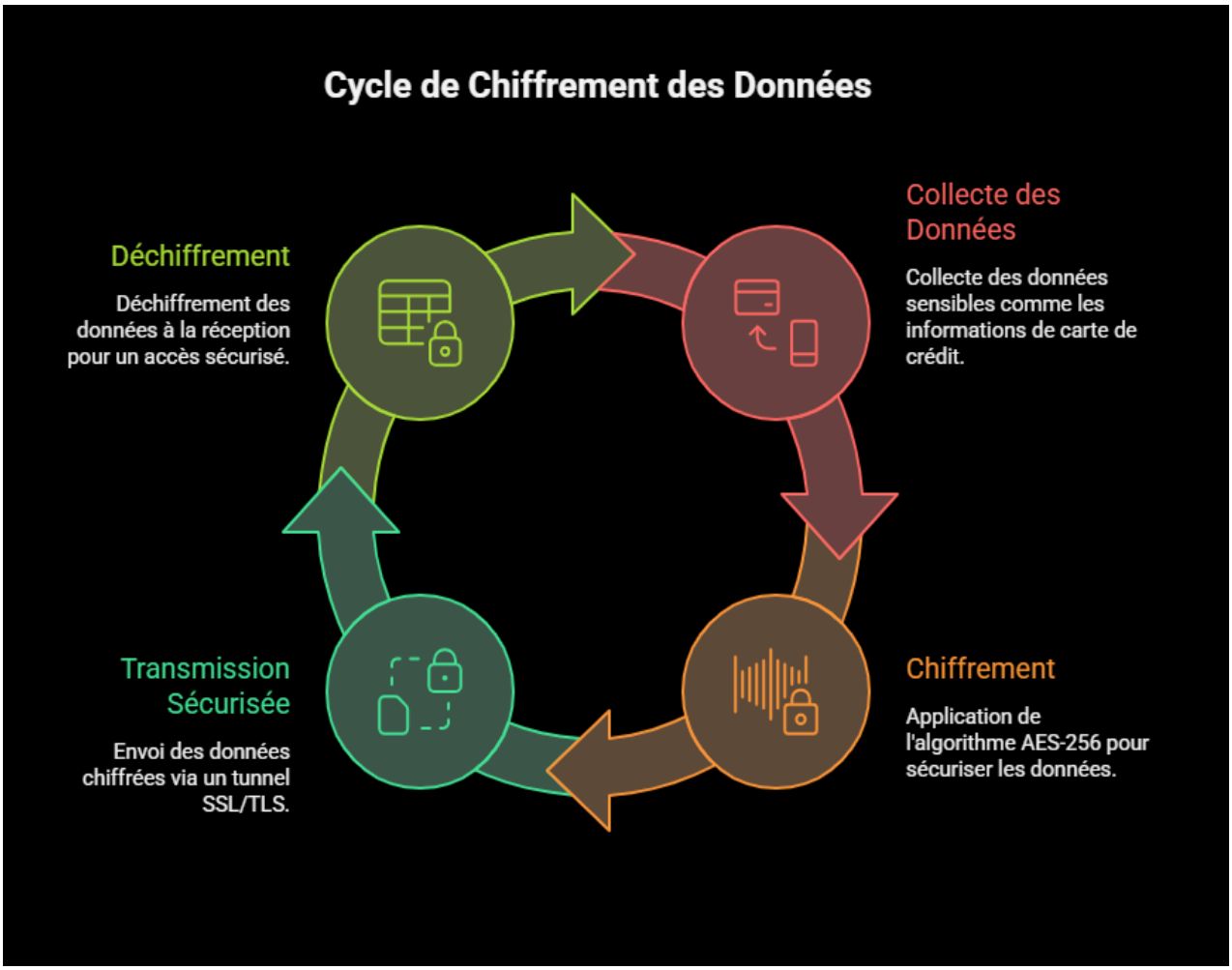
Example: If a developer changes projects, their access rights are immediately adjusted.



2. Data Security Policy

All data in transit uses SSL/TLS to protect against eavesdropping. Sensitive databases are encrypted with AES-256. This policy addresses PCI DSS Requirement 3 (protect stored data via AES-256 encryption) and Requirement 4 (encrypt data transmission over public networks via SSL/TLS).

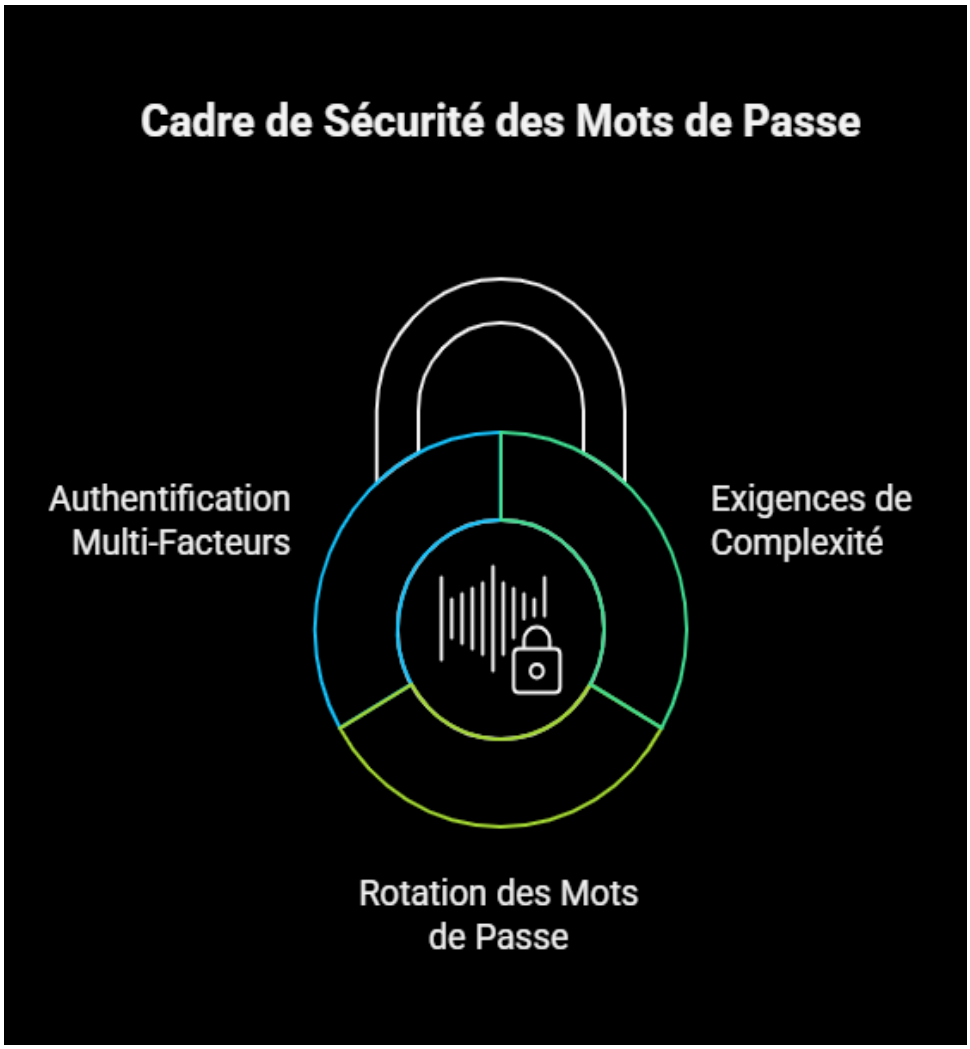
Example: Customers paying via the site see a padlock in the URL bar, indicating the connection is secure.



3. Password Security Policy

Weak or repeated passwords are prohibited. Each user must configure a complex, unique password, which aligns with PCI DSS Requirement 8 — identifying and authenticating access to system components through unique identifiers and multi-factor authentication (MFA).

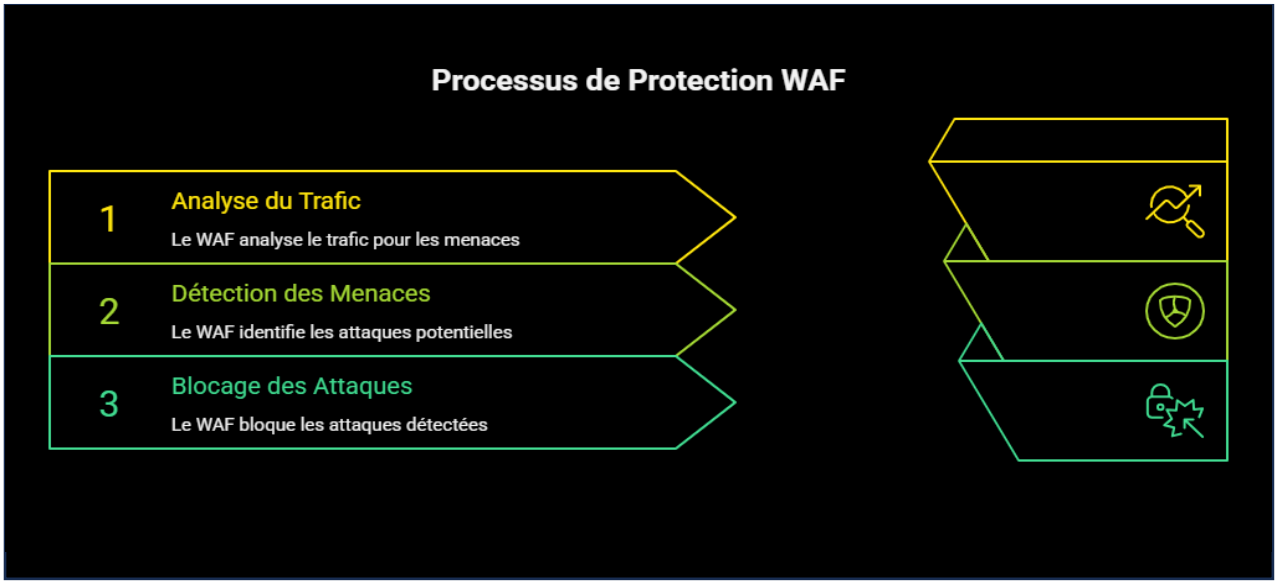
Example: If an employee forgets their password, a secure reset process is available via Active Directory.



4. Application Security Policy

Applications are tested against common attacks (SQL injection, XSS) and secured using IIS. The development team follows OWASP recommendations.

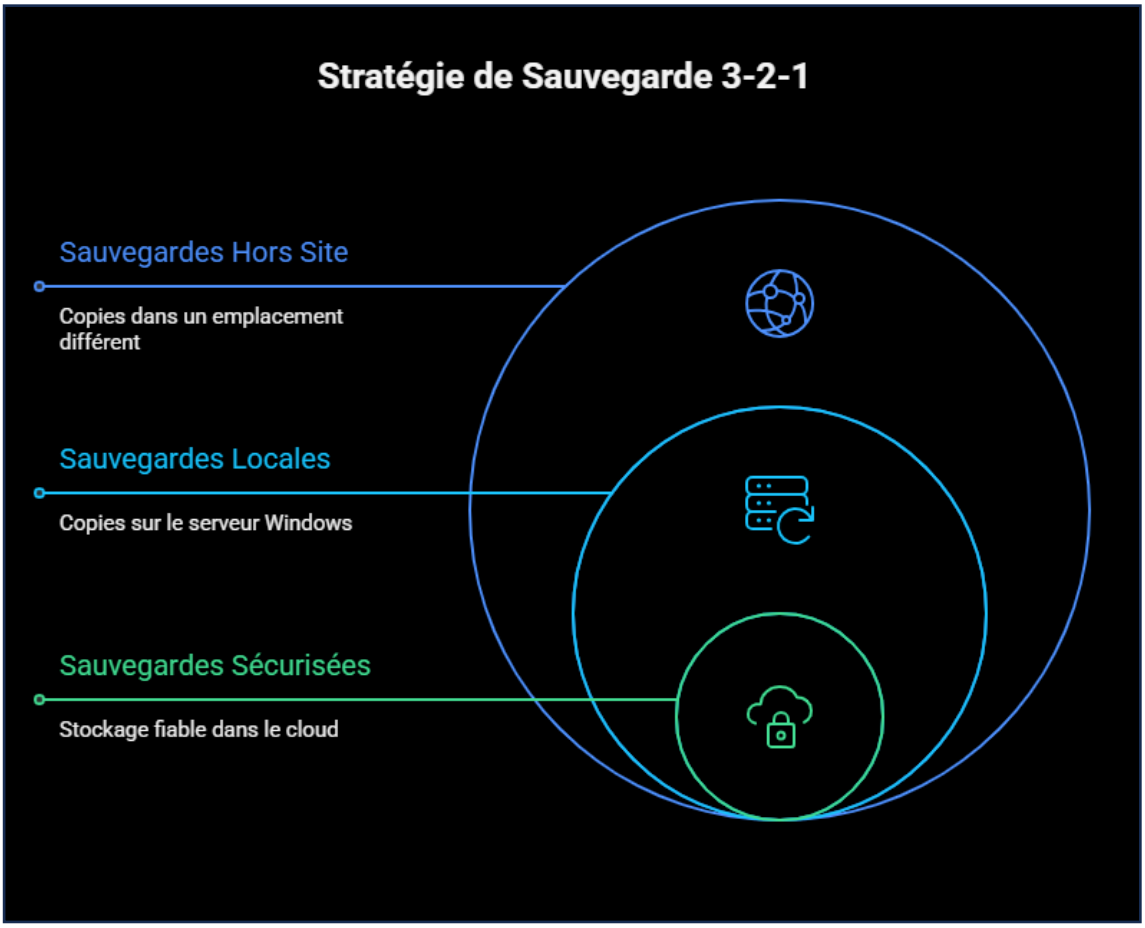
Example: Before deploying a new feature to production, a penetration test is conducted by an external provider.



5. Backup Management Policy

Backups are scheduled daily and regularly verified to ensure they are usable, using Windows Server Backup.

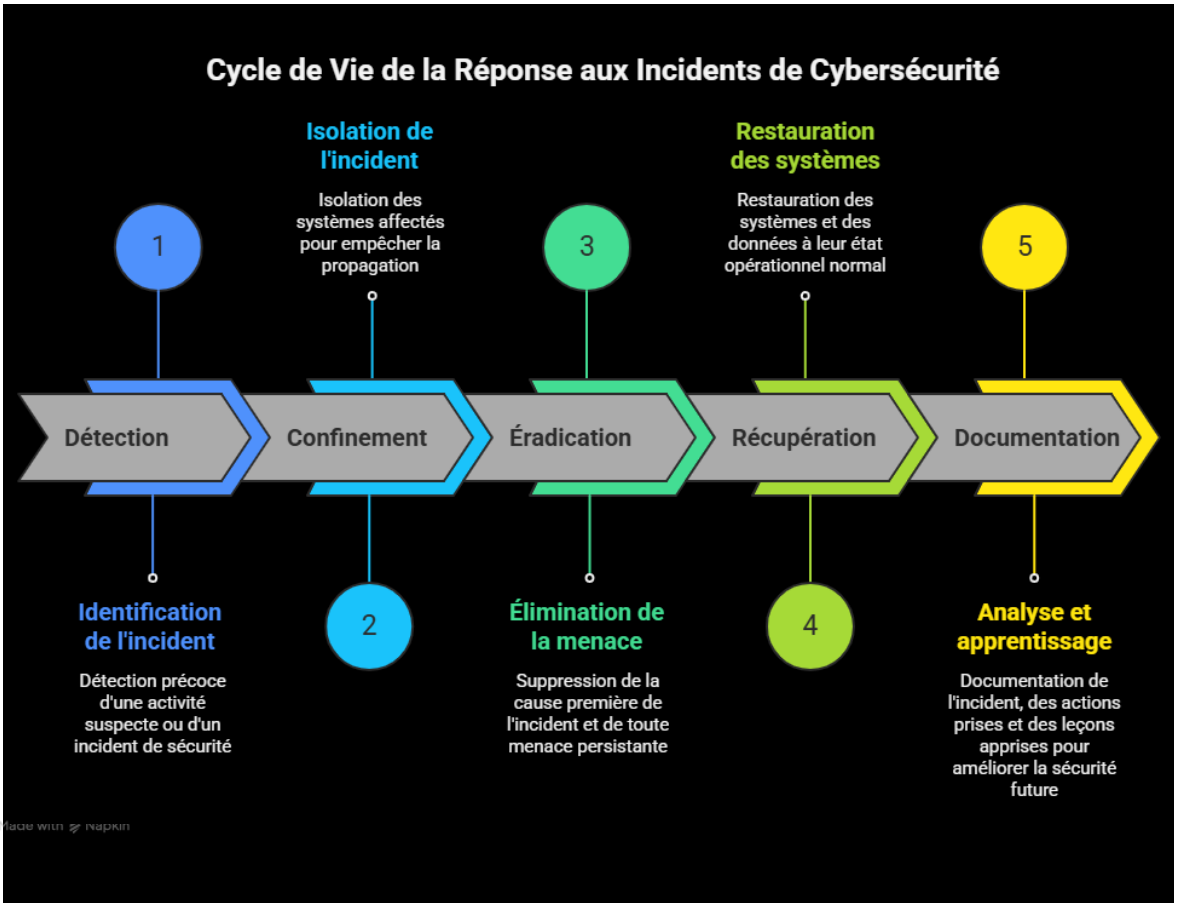
Example: In the event of a server failure, critical data is restored in under one hour thanks to cloud backups.



6. Incident Management Policy

Establishing a clear incident response chain with well-defined roles for each team member.

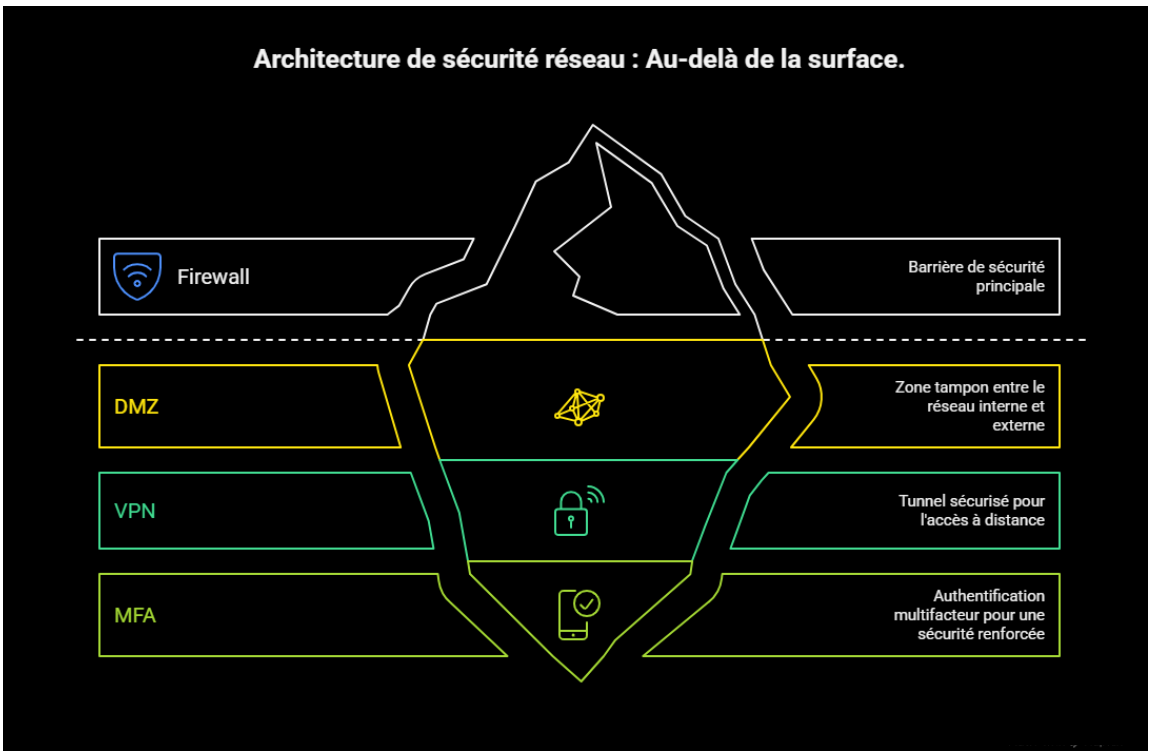
Example: If a ransomware attack is detected, the team disconnects infected systems to limit damage.



7. Network Security Policy

Network firewalls enforce strict rules. Remote connections go through a VPN with MFA authentication. This policy addresses PCI DSS Requirement 1, which mandates installing and maintaining a firewall configuration to protect cardholder data.

Example: External consultants can only access the internal network with a temporary, secured account.



:

8. Updates and Patches Policy

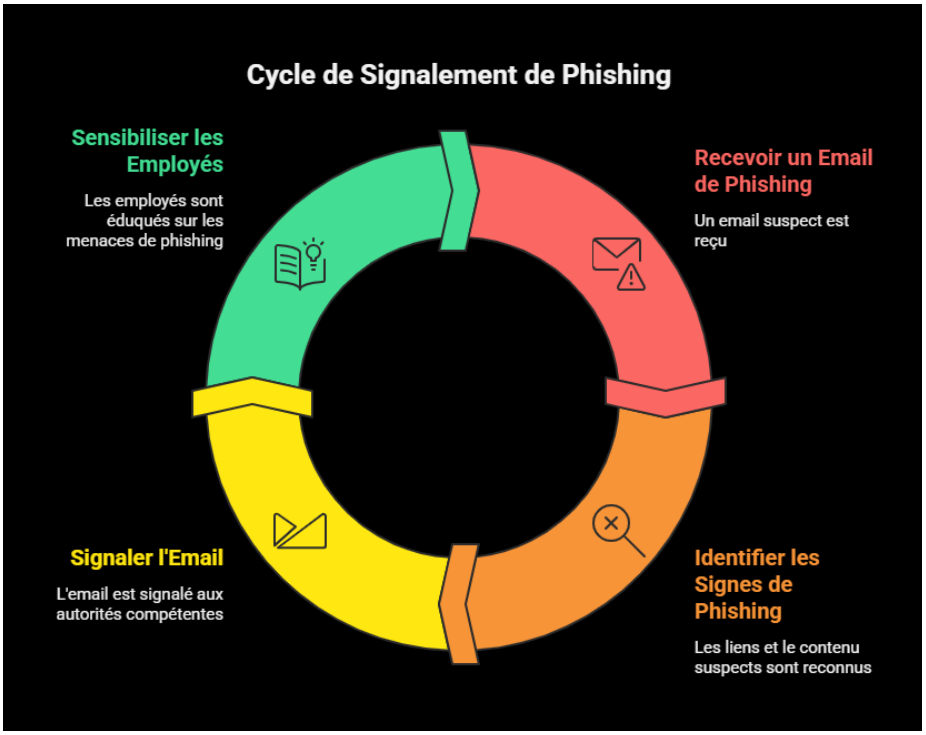
All systems must be kept up to date through a centralized process such as WSUS. This aligns with PCI DSS Requirement 6, which requires developing and maintaining secure systems and applications — notably through rapid application of security patches.

Example: A critical vulnerability alert published by Microsoft is applied within 48 hours across all servers.

9. Training and Awareness Policy

Organizing interactive sessions to explain threats such as phishing and social engineering.

Example: A simulation demonstrates how clicking on a fraudulent link can compromise an entire network.

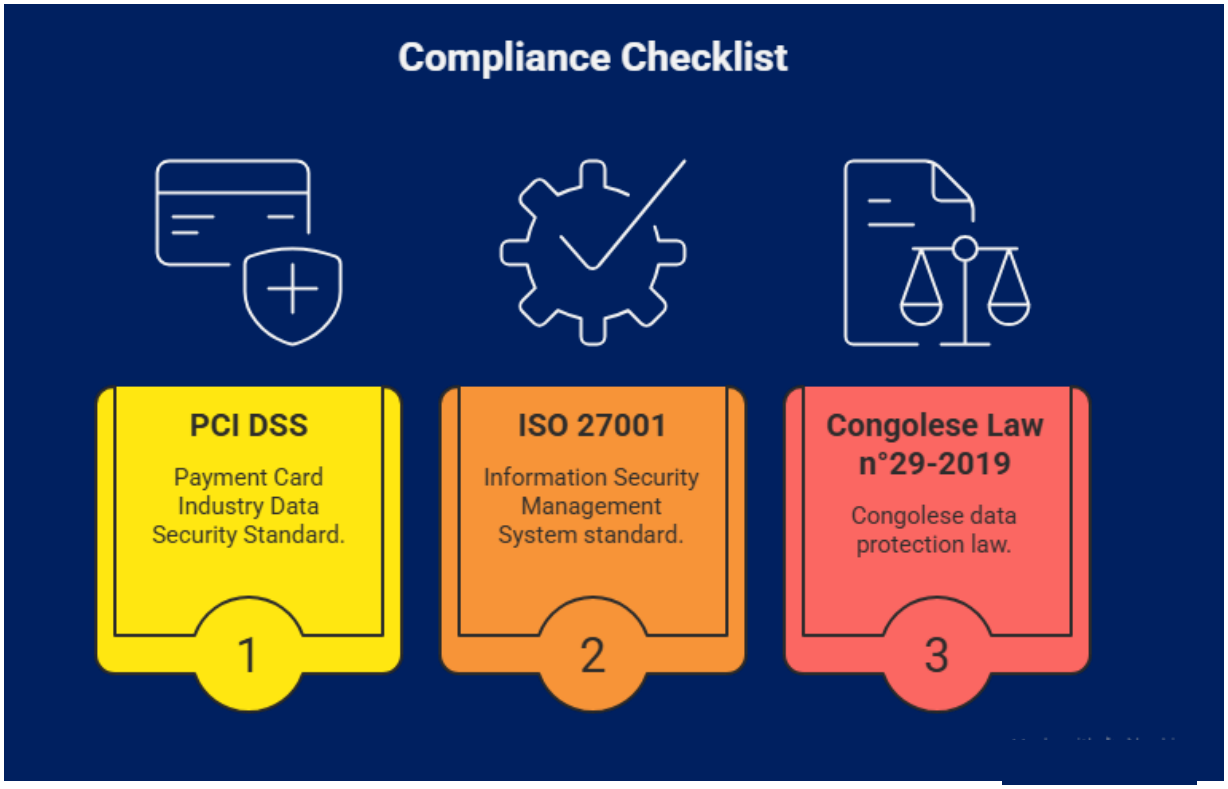


:

10. Compliance and Audit Policy

Regular audits verify whether security policies are being respected across the organization.

Example: An annual internal assessment ensures all data practices comply with Congolese law No. 29-2019.


Compliance Checklist
PCI DSS
Payment Card Industry Data Security Standard.
1
ISO 27001
Information Security Management System standard.
2
Congolese Law n°29-2019
Congolese data protection law.
3

V. EMERGENCY PLAN: WHAT TO DO IN CASE OF AN INCIDENT?

1. Identify Risks

Example: identifying a ransomware attack blocking the servers.

2. Proactive Detection

- Use tools such as Snort to monitor system logs.
- Real-time analysis of network alerts.

3. Rapid Response

- Immediate disconnection of compromised systems.
- Notification of affected customers and partners.

4. Recovery

- Data restoration via backups and system replication.
- Application of patches to close exploited vulnerabilities.

5. Continuous Improvement

Document the incident and extract lessons learned to prevent recurrence.

VI. CONCLUSION

In conclusion, with these defined policies and an emergency plan in place, SRI Pay Online will be equipped to protect its customers' data, ensure service continuity, and comply with applicable regulations. Cybersecurity is a never-ending race: these policies must therefore be regularly updated to keep pace with emerging threats including zero-day attacks. Complacency is not an option when handling financial and personal data at scale.